

Alias Equals Zone?

Large-Scale and Stealthy Takeover of Domain Hosting Service via CNAME-Following Cross-Domain Verification



USENIX

Ruixuan Li, Xingyu Zhao, Yunyi Zhang, Baojun Liu, Jun Shao

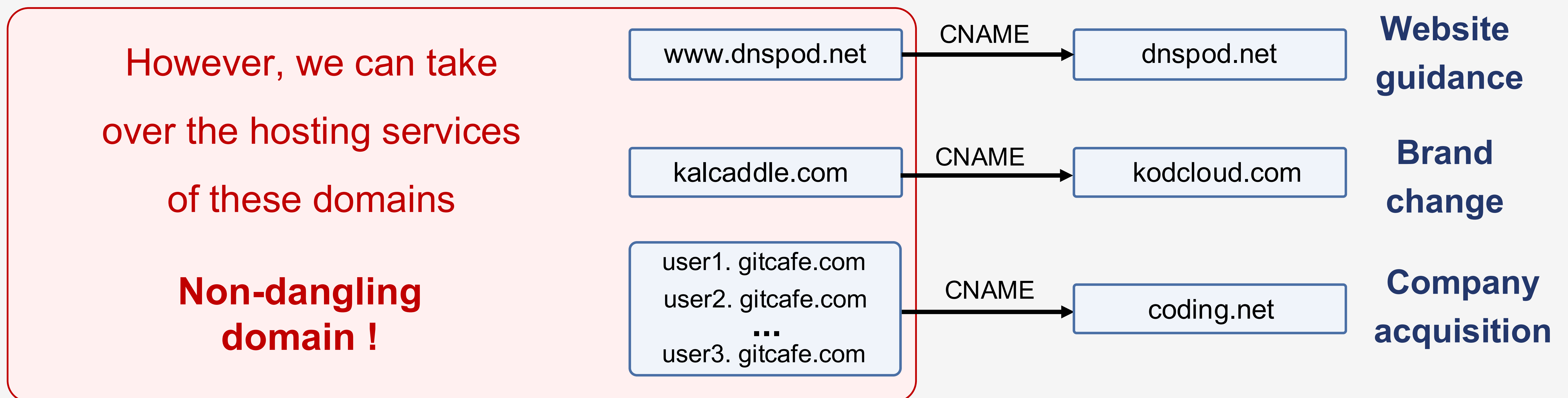
A novel domain takeover attack (AliasLeap)

Attack Goal: Take over the email and website hosting services of victim domains.

Attacker Ability: No need to control any DNS records, deploy any servers, perform any illegal operations.

Attack Harm: Deploy phishing websites, send forged emails, obtain valid certificates, theft of user privacy, etc.

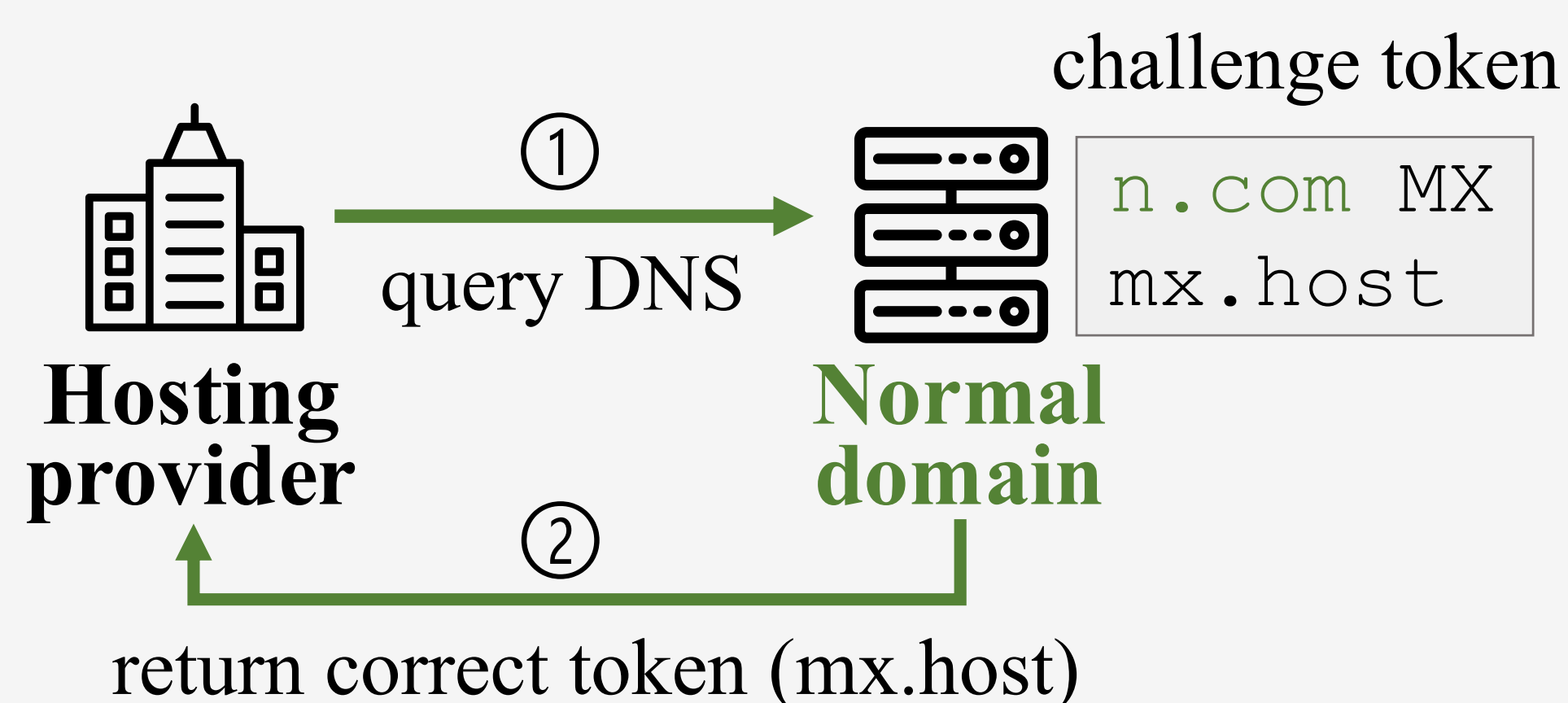
The core role of a CNAME is to map one domain to another during DNS resolution



All CNAME configurations are common and legal

Normal DOV Logic

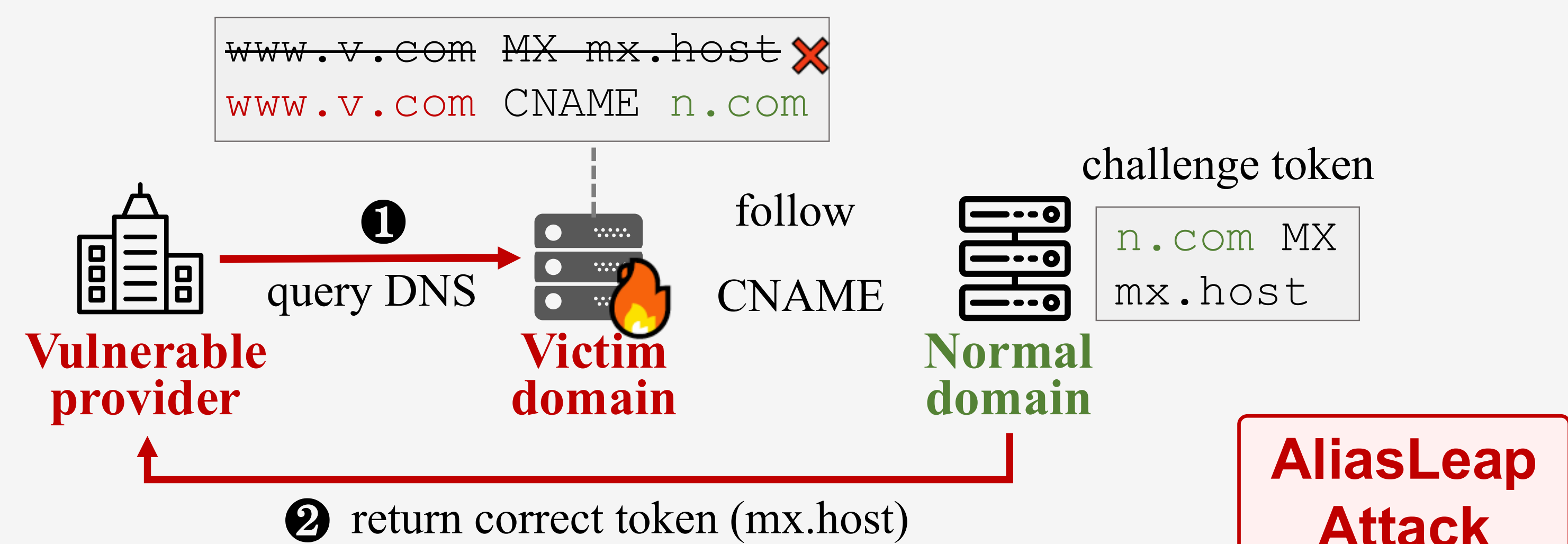
Provider requires the customer to configure specified DNS records for the domain



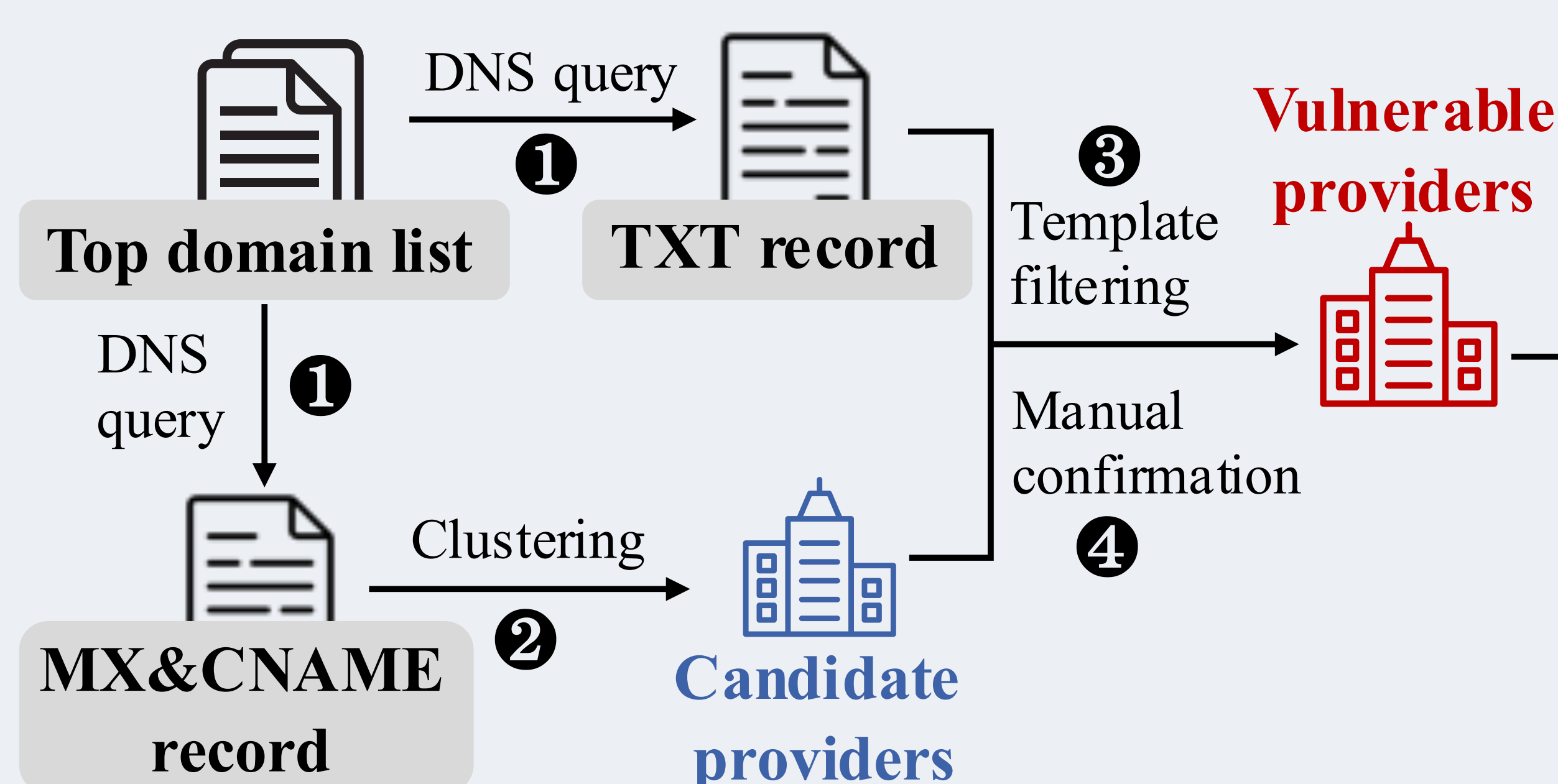
VS.

Vulnerable DOV Logic

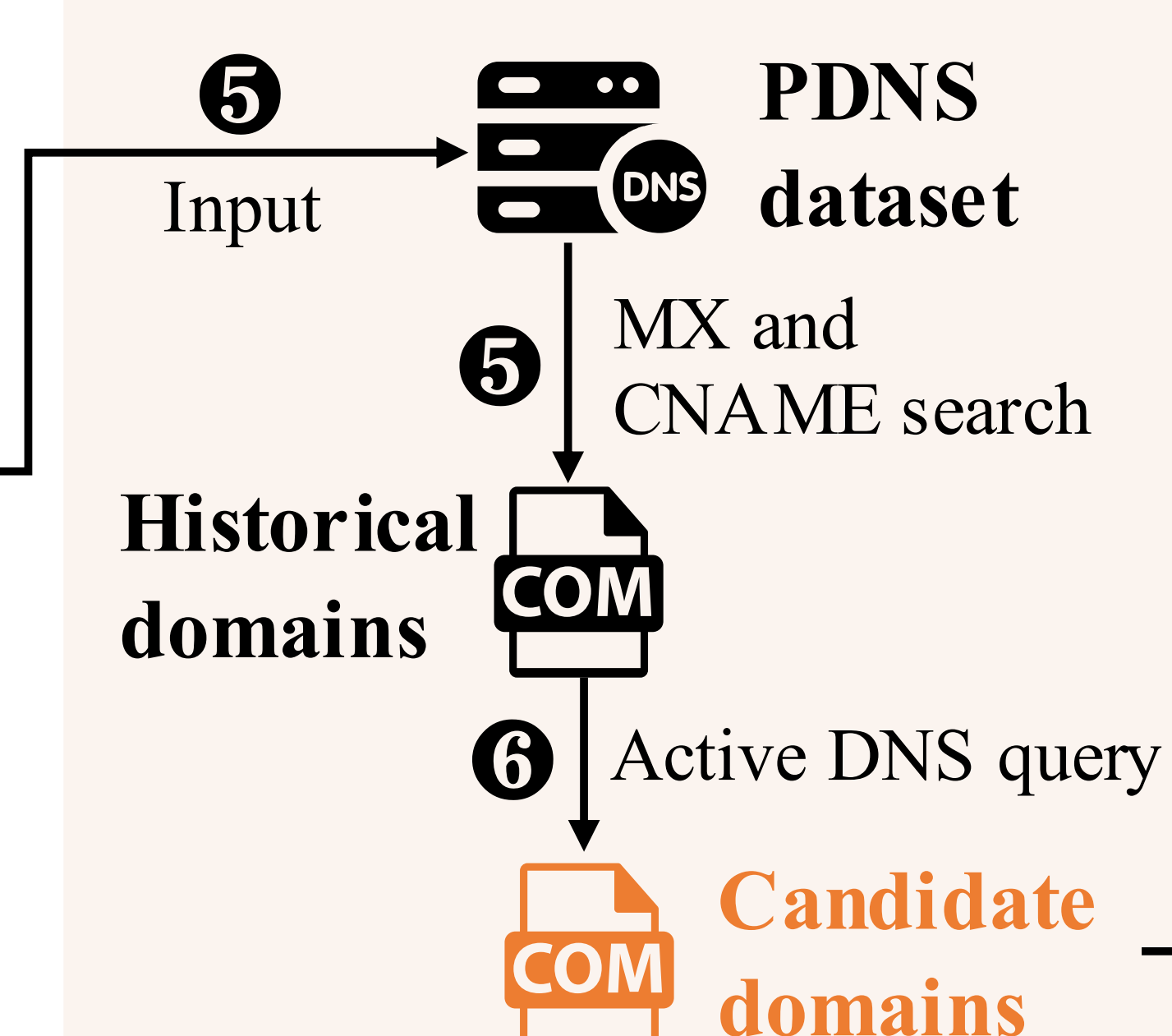
During the DOV process, many providers follow the CNAME record to cross-domain verify the DNS record



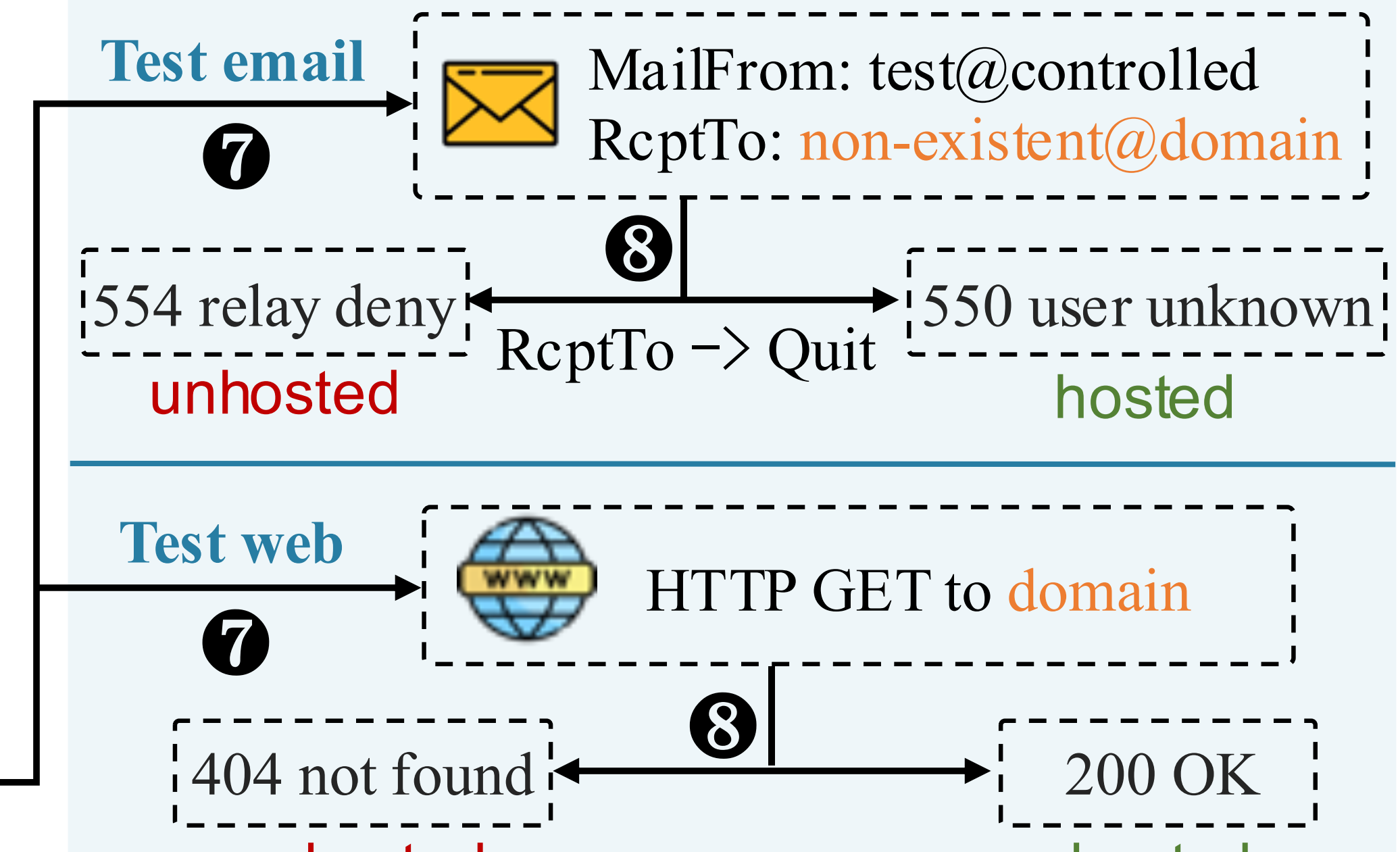
Step I: Identify Vulnerable Hosting Providers



Step II: Collect Domains



Step III: Detect Vulnerable Domains



14 popular domain service hosting providers are affected



More than **2 million** domains can be taken over, 19819 domains at risk for longer than **10 years**

Contact: Ruixuan Li, <https://ruixuanli.com>, lirx25@mails.tsinghua.edu.cn

